MACHINE SECURITY TESTING AUDIT REPORT

Document:	Machine Security Testing Report
Prepared By:	Nikunj Kumar
Report Content:	Detailed Technical Report
Status:	**Completed**
Machine & IP:	**Pumpkin Garden & 165.232.191.208**

Prepared BY

NIKUNJ

Disclaimer

Pumpkin Garden in the first in a series of beginner boxes on VulnHub. It is geared towards beginners and if you are just starting out with **ethical hacking** and **penetration testing** this is a great box to get started with. I really like that there is a box that is more realistic than caesar cipher **capture the flag problems**, but can still be solved by people new to hacking. I tried to be as verbose as possible and to explain things that might get skipped over in **more advanced walkthroughs**, but I am sure I missed a thing or two.

Today we are going to solve another CTF challenge known as mission Pumpkin and credit for making this **VM machine** goes to **Jayanth** which is designed for people who are beginners in the **penetration testing** field. The mission of this CTF is to gain access to **PumpkinGarden_key** file stored in the root account. So, let's proceed towards solve this **Mission Pumpkin.**

I am Tested this Vulnerable machine through Virtual Box.

Table of Contents

1. Ip Discover.....4
2. Scanning.....4-5
3. Web Server.....6
4. FTP Login.....7
5. Enumerate : Dirb Scan.....8
6. Web Directories.....9-10
7. Exploiting.....11-12
8. Root Access.....13
9. Done/Complete.....14

Detailed Vulnerability Information

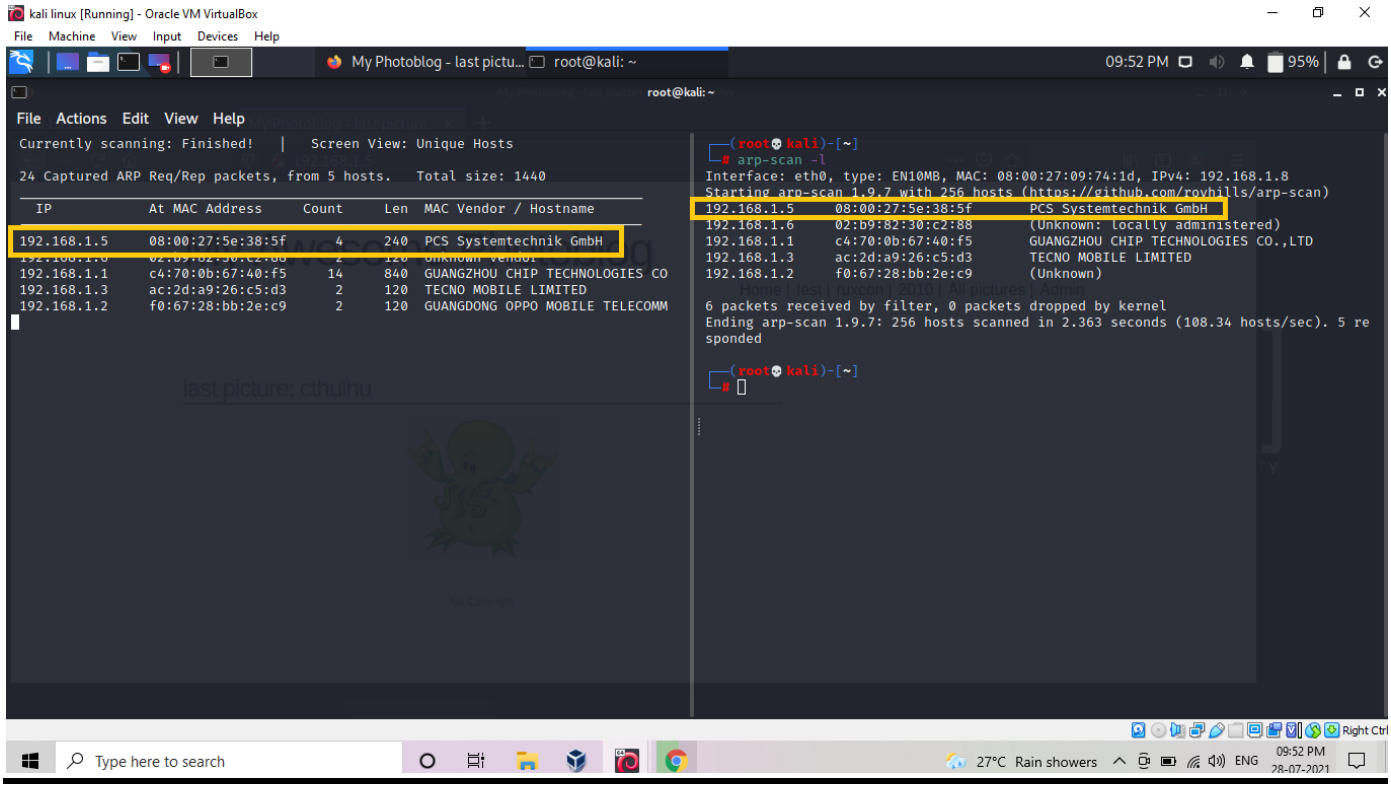
The detailed explanation of the vulnerabilities as well as the recommendations for the same are explained below.

Risk :
Low

1.IP Discover

First, we need to identify the IP of this machine. Let's use netdiscover to identify the IP. Below we can see netdiscover in action. The IP of the victim machine.

cmd - 1. **netdiscover**

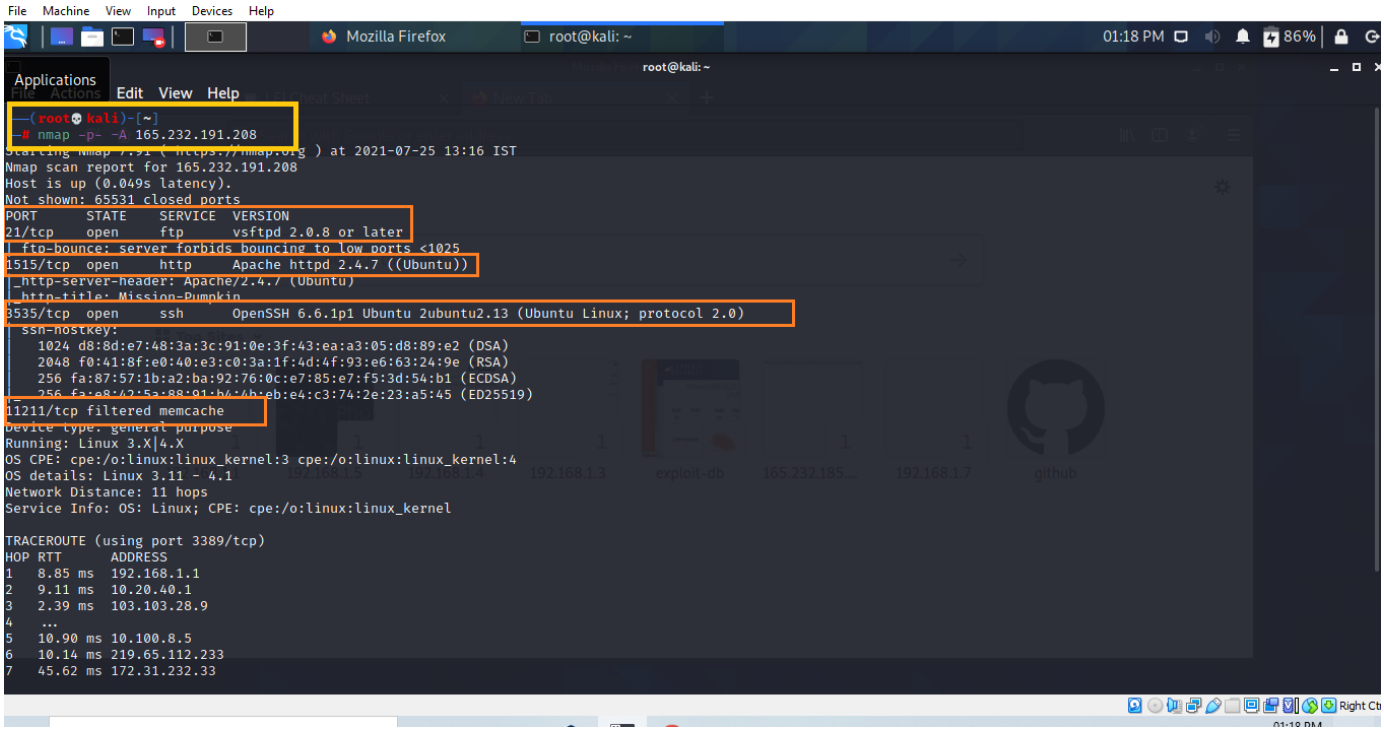


2.Scanning

Let's Start

As always the real game starts with the **enumeration** part so I did **Nmap scan** first and found **Ports** are open or not.

cmd- **nmap -p -A 165.232.191.208**



Nmap the well known network scanner,
I used it to get the **open ports** so I can design my plan for attacking the machine.

It is a **web server** so need for scanning other ports & services.

It show **open Port** of these two---

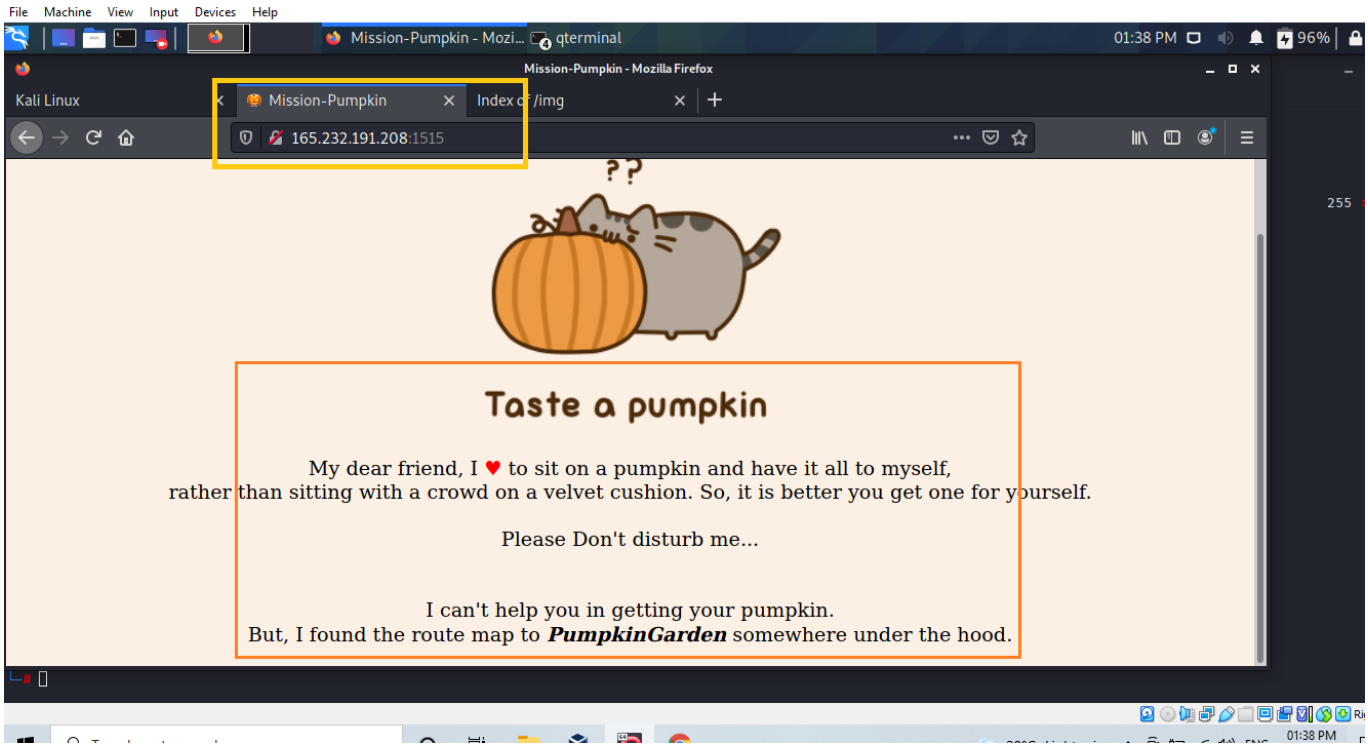
ssh - 3535/tcp

http- 1515/tcp

ftp- 21/tcp

3.WEB SERVER

Okay, enough information from the **NMAP** let's jump strait away to the **web service**!



Nice website....

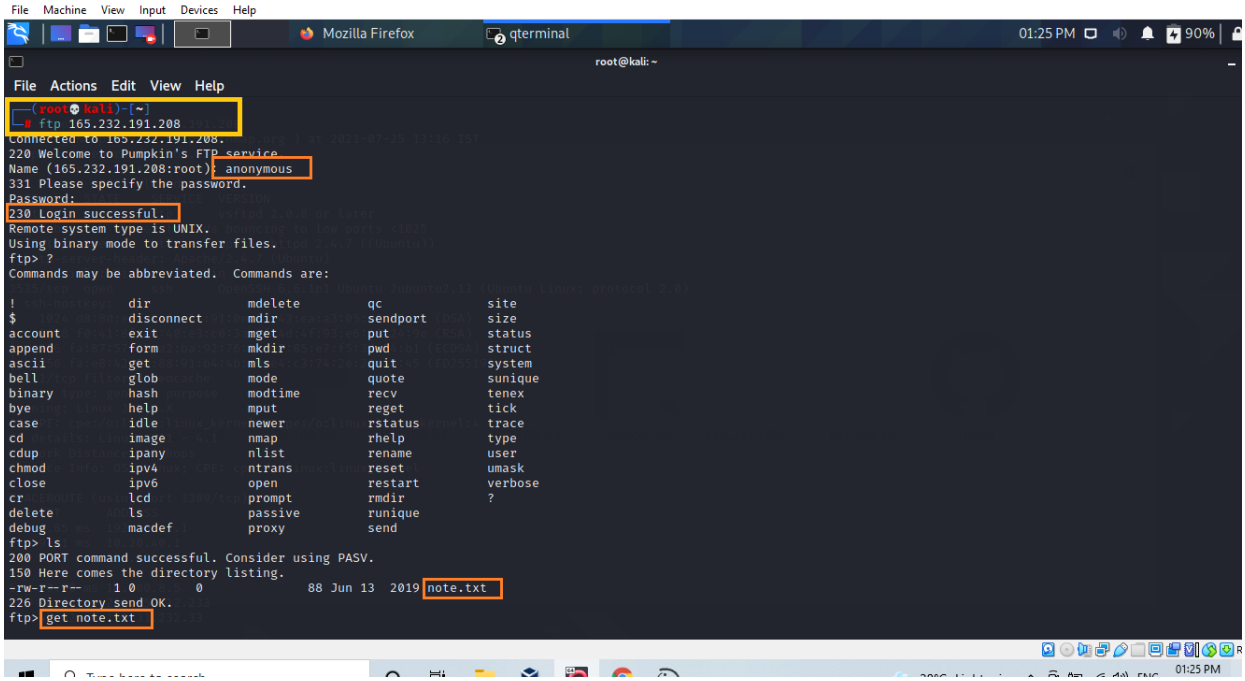
I also had a look to main **Page** and I found this, as it was their **official page**.

Opening a browser and accessing the HTTP server running on port 1515 shows the homepage:

Let's **visit** the pages and see if we can get something.

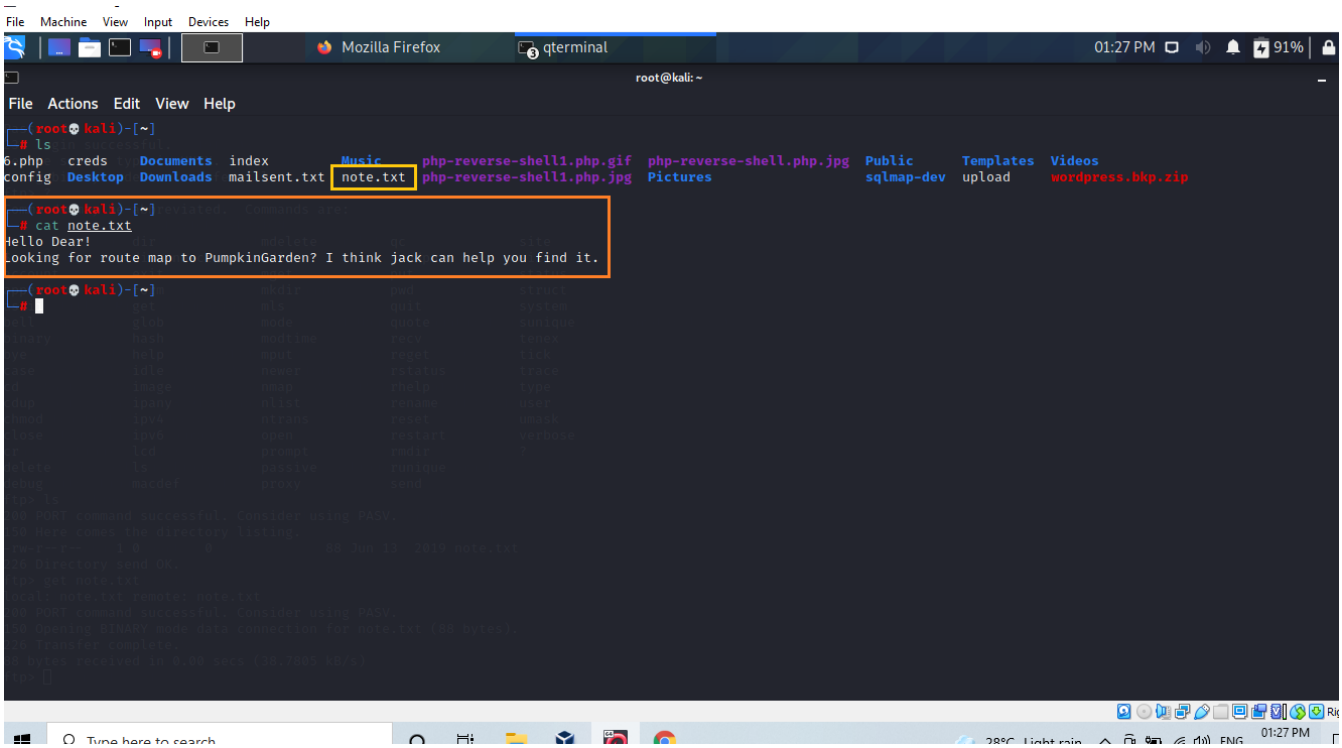
4. FTP check

The nmap scan shows anonymous FTP login is allowed, so this will be worth a look. We can connect to this service by running the following command and entering *anonymous* as the username, with any password:



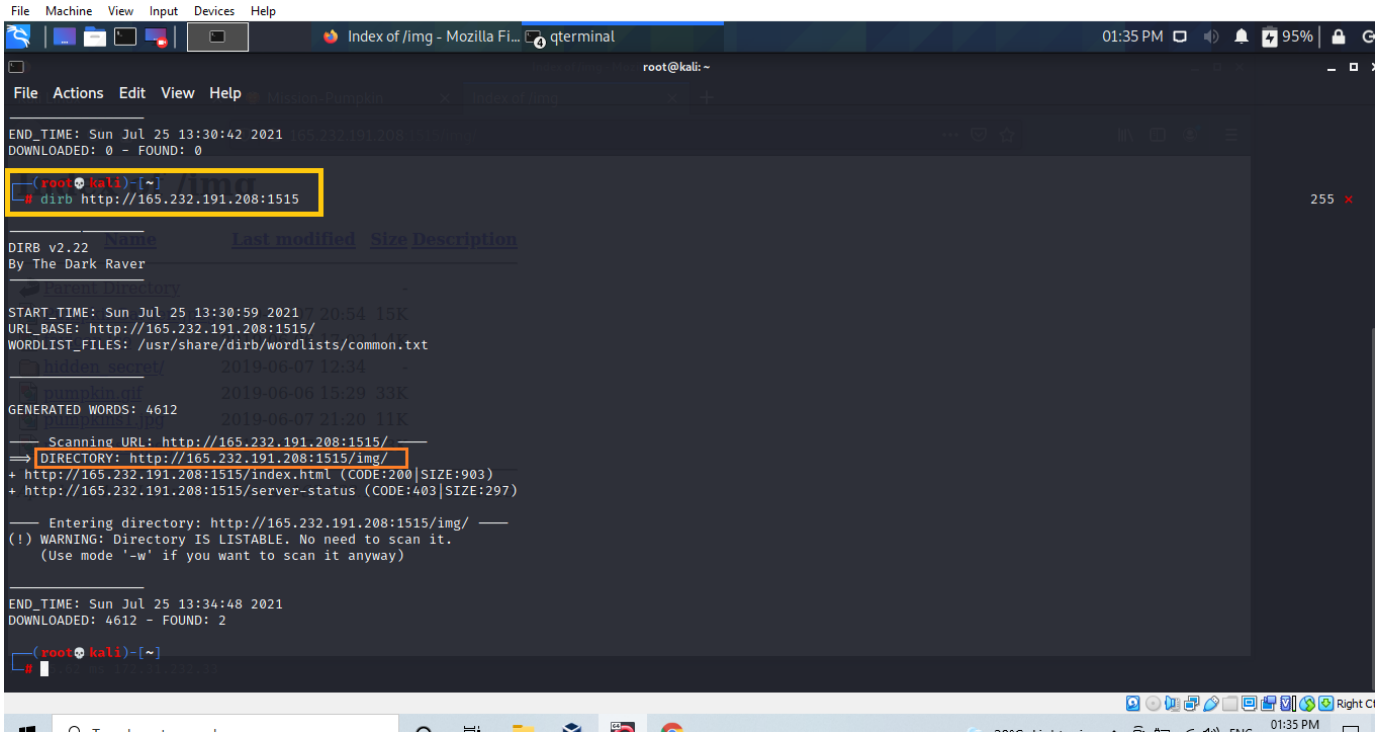
Found- **note.txt**

Then open it given below..



5.Enumerate: Dirb scan

The comment written in the page source wanted us to search for the next clue in pumpkin images. We can use **dirb** to enumerate web directories.



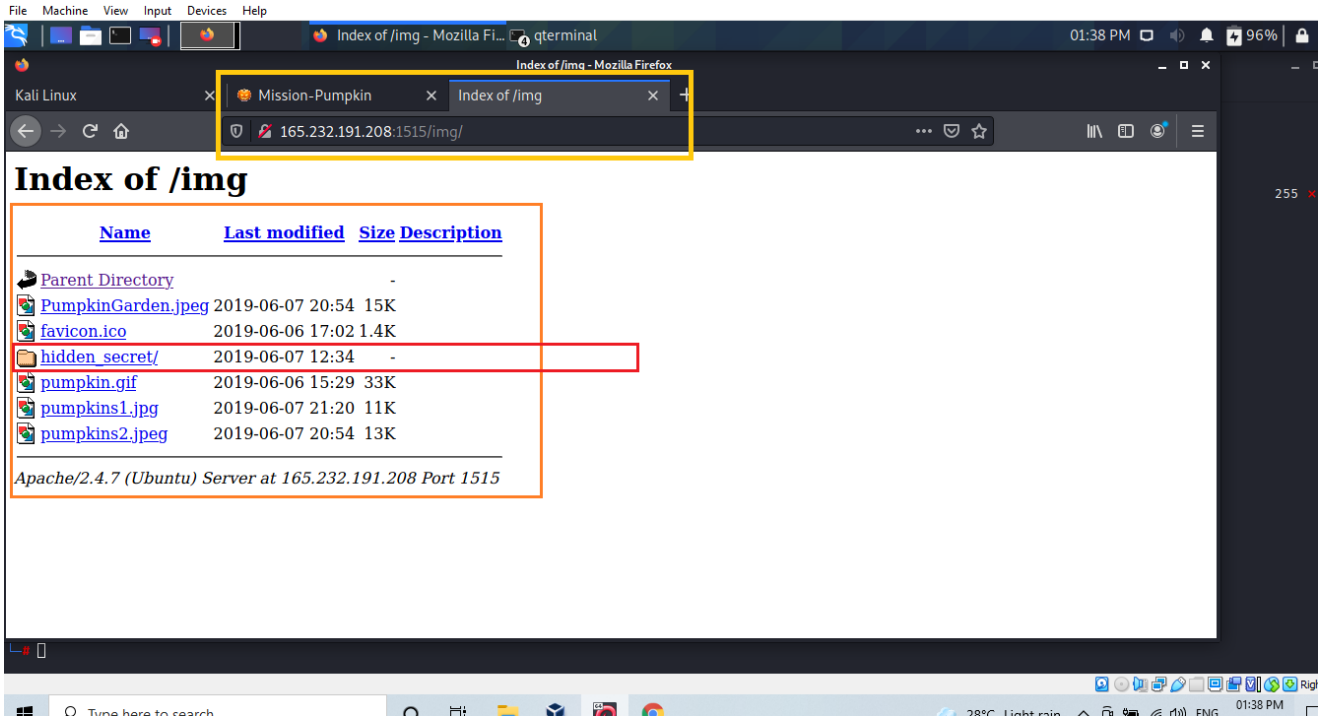
`DIRECTORY: http://192.168.1.102:1515/img/`

We are allowed to list **img** directory contents.

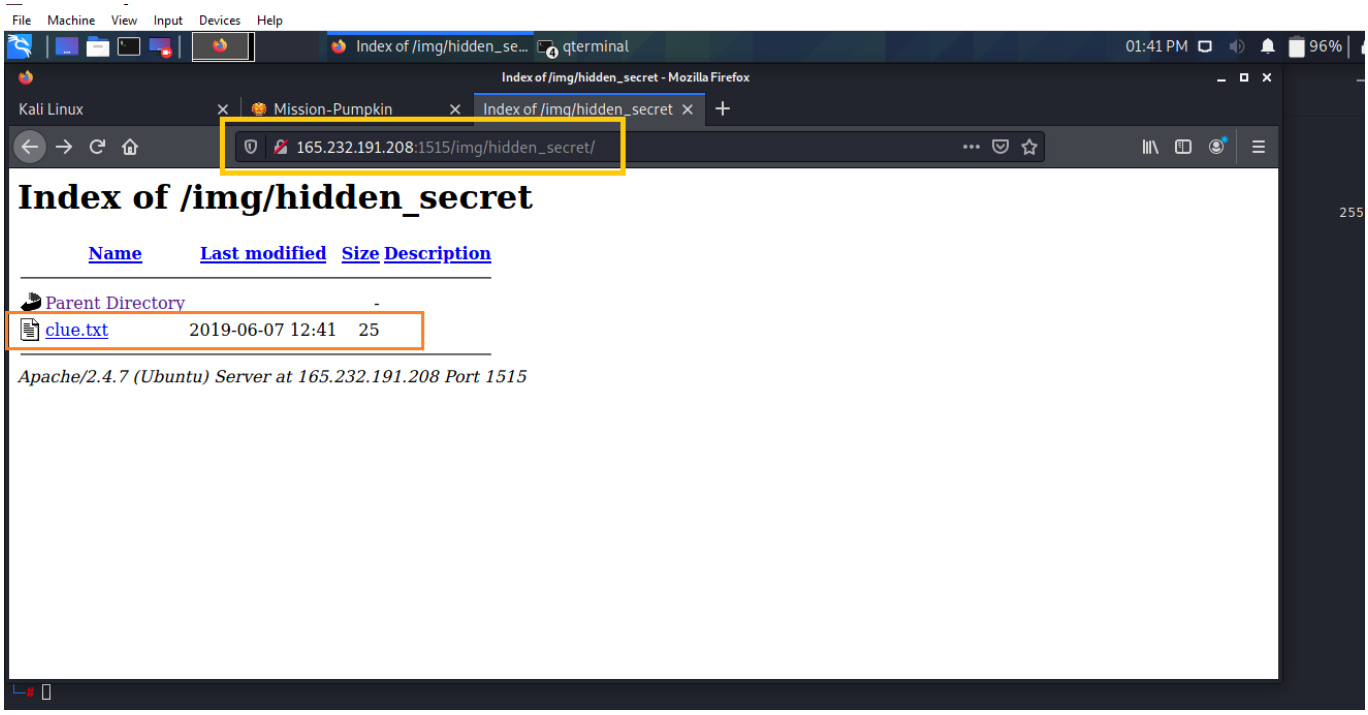
The URL looks like `http://10.133.1.4:1515/img/` and presented to us on the screen is our route map.

5. Web Directories

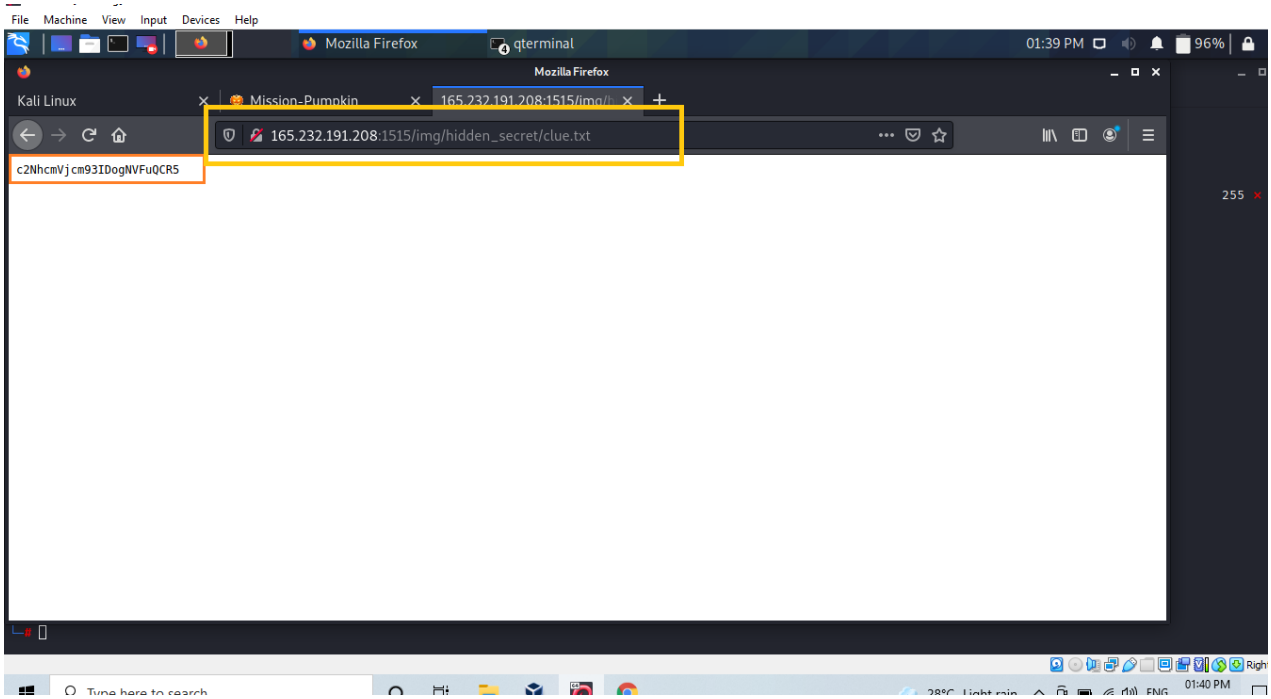
We can see in the URL bar that the image is stored.



The folder named “hidden_secret” is pretty obviously what we need. Inside of that we find a file named “clue.txt”, which will most likely contain our next clue.

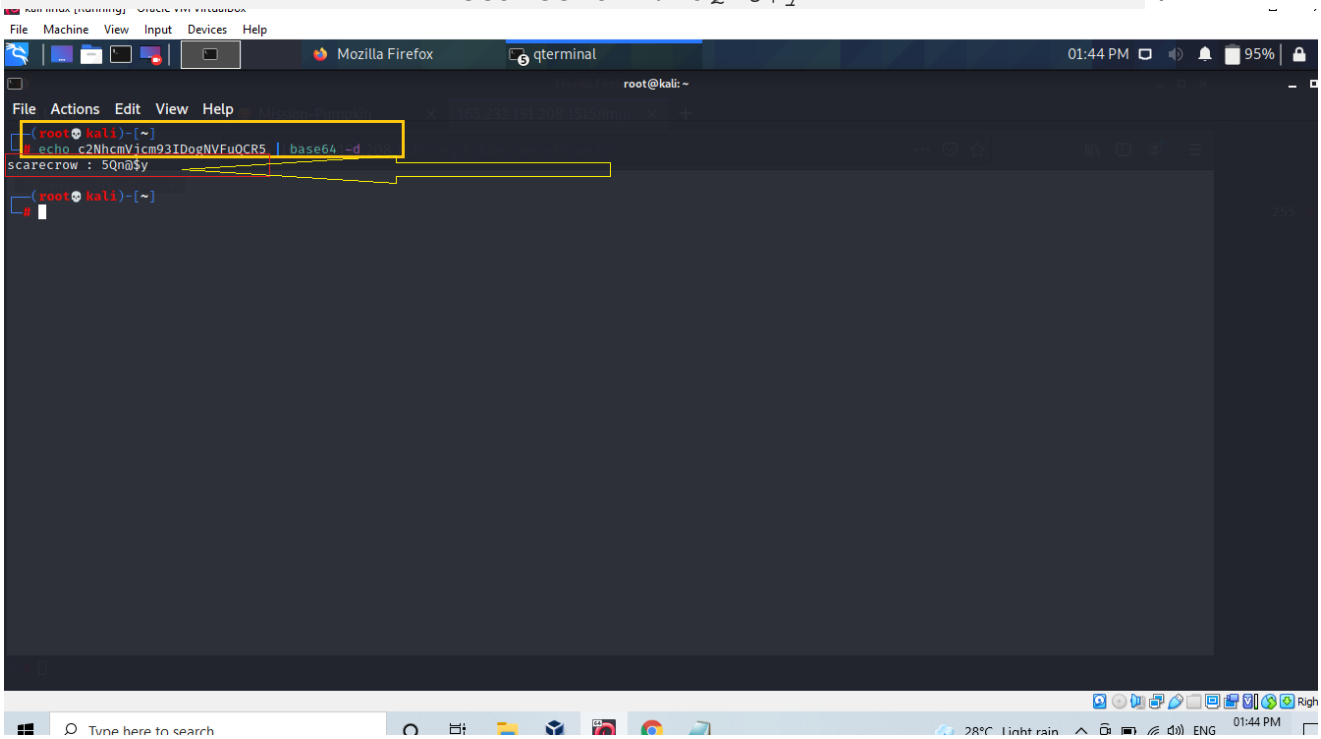


Clicking on the file renders it's contents in our browser, and the we see that the file contains the string `c2NhcmVjcm93IDogNVFuQCR5`.



We can google for an online base64 converter, or use the base64 program built into most Linux OS's and decode this string. The result is our first set of credentials,

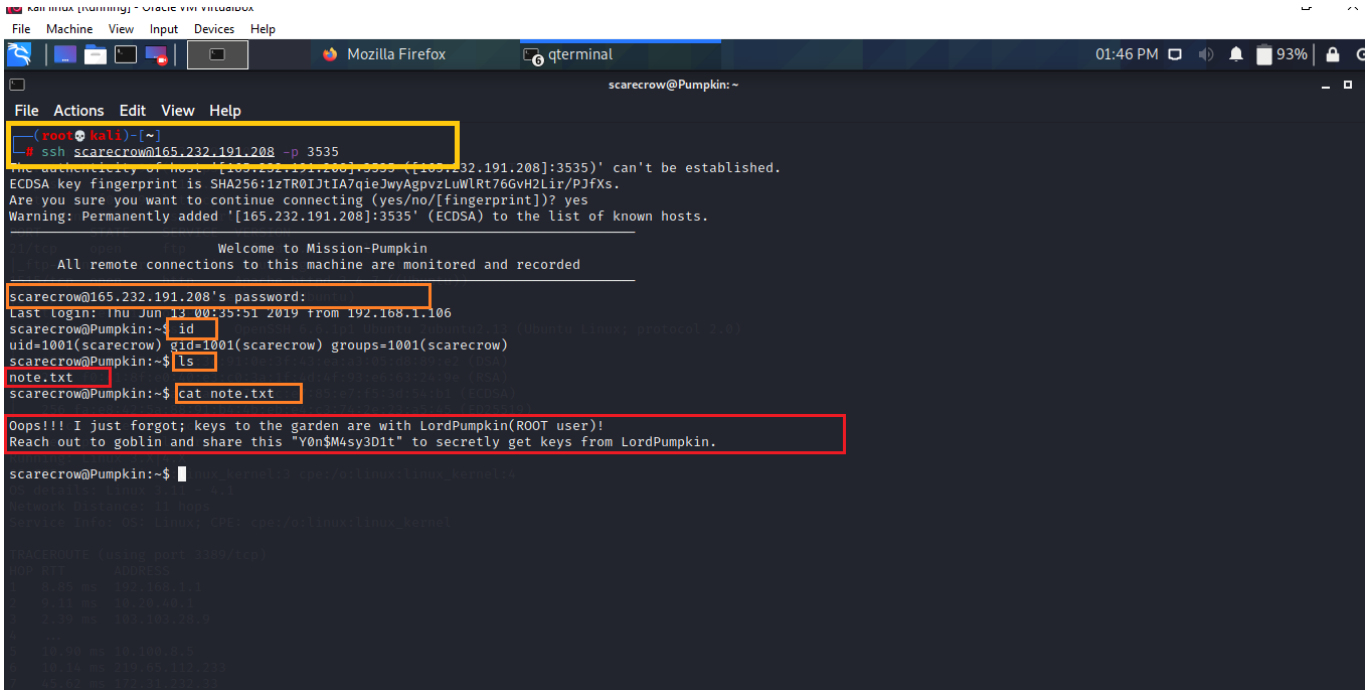
`scarecrow : 5Qn@$y`.



7.Exploiting

Earlier in our nmap scan we saw that port 3535 was open for ssh connections, and now we can log in using these newly found credentials. The actual command line code to do this is `ssh scarecrow@165.232.191.238 -p 3535`.

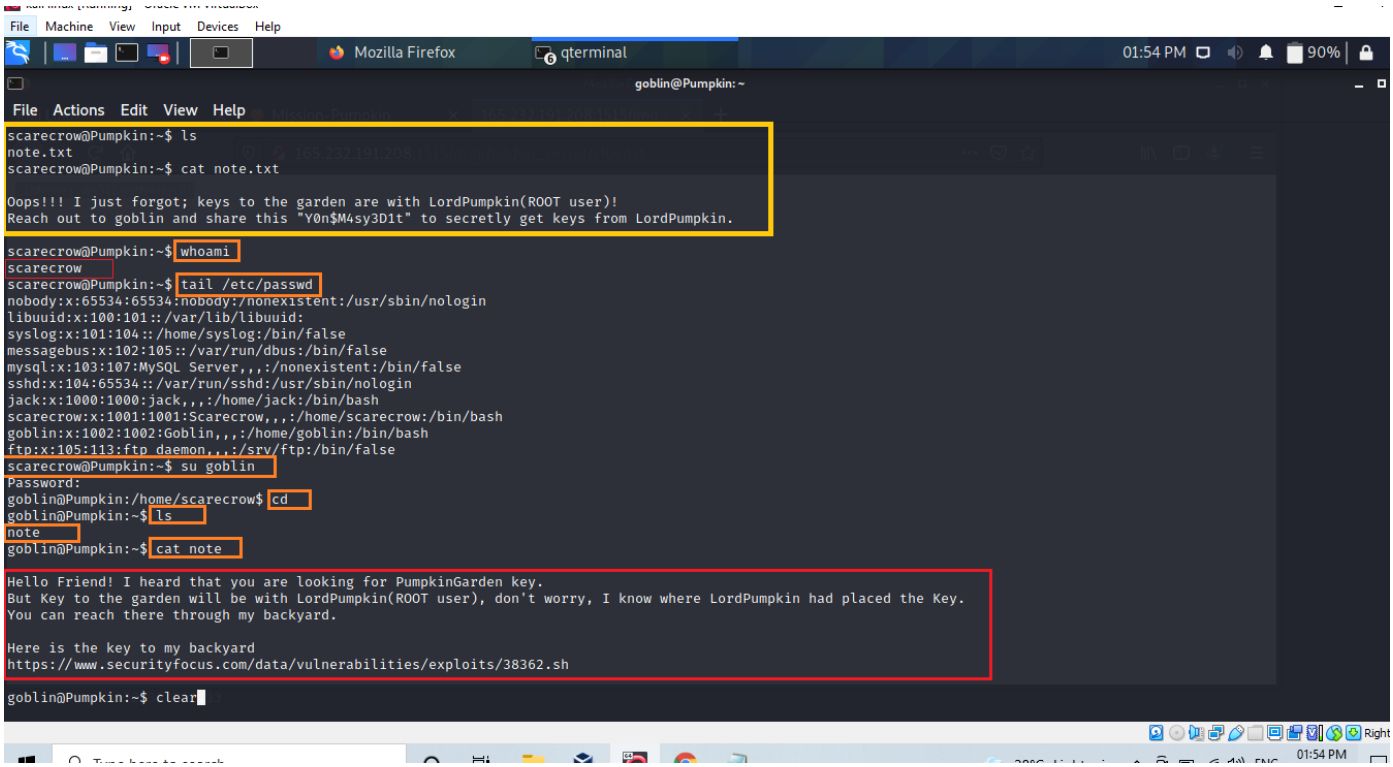
As soon as we log in we prompted for a password, and here we enter **`5Qn@$y`** .



. Success! We are now logged in as scarecrow.

Now we will try to connect through ssh with help of credential found above. after login as scarecrow here we have found file **note.txt** and after opening this we will get another clue which is password. So further we will check the list of users in **etc/passwd** file.

We got the list of users, now we will switch to **goblin** user and enter the password key *Y0n$M4sv3D1t* and we are successful login by doing so.

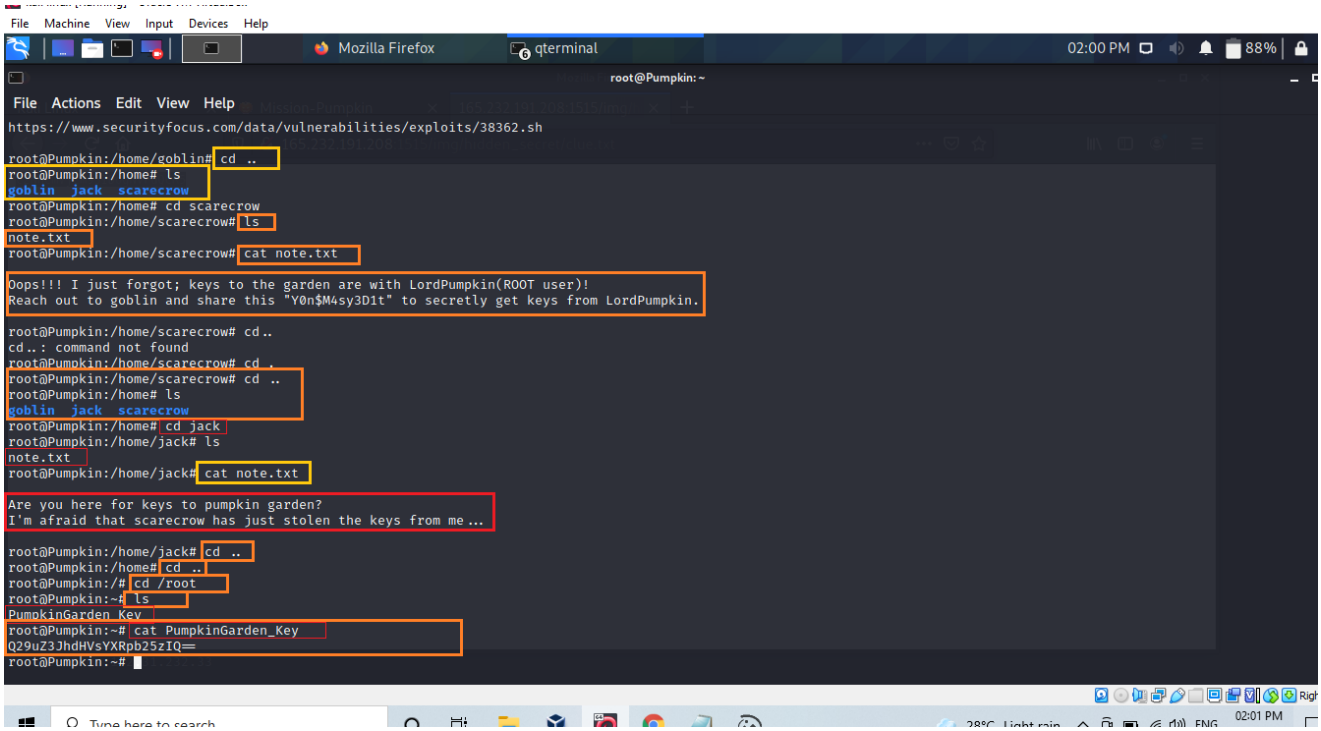


In goblin user, we found another note file which contains a link of exploit db for exploiting as shown in the image at the bottom.

Now we will click on the link which is provided there and downloaded the bash file which holds the method to gain access of root.

8.Root access

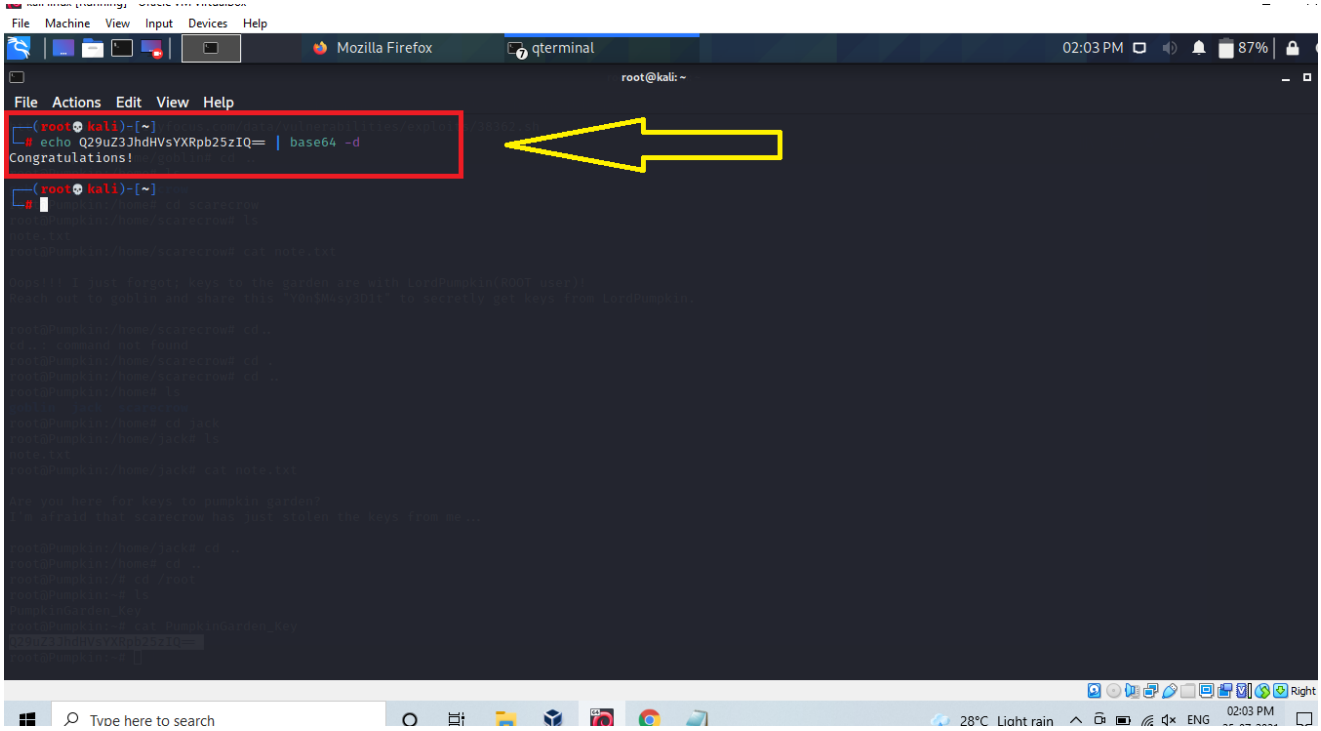
Finally, we reached a place where we found a way to gain **root** access. Its time to escalate privileges.



We need to make the file executable before we run the script to gain root access.

So, as we run the commands which we have got we will get the root access and we are logged in as root. We have got **pumpkeygarden_key** here which reflects that we have solved this **CTF** successfully.

The **flag** can then be obtained by switching to the home directory, reading the contents of ***'PumpkinGarden_Key'*** and then **Base64 decoding** it:



9. COMLETELY DONE

So, I am done writing this long walkthrough -.-
I just hope you liked it and enjoyed this long read!

Complete this Challenge...(CTF)